

DEVOIR DE SÉCURITÉ LOGICIELLE

Groupe : Hosts and Systems

Sécurité système sous Ubuntu 22.04 LTS — Analyse, Tests & Résultats

Auteur du rapport	MASSE MASSE Paul-Basthille
Chef de Groupe	SEGNING WOUATI Gildas
Module	Sécurité Logicielle — Hosts and Systems
Système cible	Ubuntu 22.04 LTS (paulo — 192.168.2.100)
Outils utilisés	Nmap 7.80, OpenVAS/GVM, UFW, PAM, auditd, Lynis, rkhunter
Date	18 avril 2026

Note méthodologique : Ce rapport présente les outils étudiés par le groupe Hosts & Systems. Chaque outil constitue un domaine d'exploration individuel. Les tests Nmap ont été effectués en conditions réelles. OpenVAS est en cours d'installation — son analyse approfondie (scan de plusieurs heures) fera l'objet d'un complément. Lynis, rkhunter, auditd seront testés par les autres membres du groupe.

GRANDE PARTIE 1 : PRÉSENTATION & DÉFINITIONS

Cette section présente les concepts fondamentaux et les outils de la sécurité système. Elle couvre la gestion des accès et des privilèges, les outils d'audit et de détection, ainsi que les scanners de vulnérabilités utilisés sous Ubuntu 22.04.

1.1 — Gestion des Utilisateurs, Groupes et Privilèges

1.1.1 Types de comptes sous Ubuntu

Linux distingue trois niveaux de comptes utilisateurs :

- **Compte root (UID=0)** : accès total au système. Son utilisation directe est déconseillée. On préfère passer par sudo.
- **Compte administrateur (sudo)** : utilisateur standard pouvant exécuter des commandes root via sudo. Modèle recommandé en entreprise.
- **Compte standard** : droits limités au répertoire personnel. Ne peut pas modifier les fichiers système ni installer des logiciels globaux.

1.1.2 Commandes de gestion des utilisateurs

```
sudo useradd -m -s /bin/bash -c 'Jean Dupont' jdupont # Créer un utilisateur
sudo usermod -aG sudo jdupont # Ajouter au groupe sudo (admin)
sudo usermod -L jdupont # Verrouiller un compte
sudo passwd jdupont # Définir/changer le mot de passe
sudo passwd -e jdupont # Forcer changement au prochain login
```

1.1.3 Gestion des groupes

Les groupes permettent d'organiser les utilisateurs et d'attribuer des permissions communes. En entreprise, on crée des groupes par département (RH, IT, Finance) et on restreint les accès selon l'appartenance au groupe.

```
sudo groupadd developpeurs
sudo groupadd comptabilite
sudo usermod -aG developpeurs alice # Ajouter alice au groupe
getent group developpeurs # Voir les membres
sudo gpasswd -d alice developpeurs # Retirer alice du groupe
```

1.1.4 Sudo et /etc/sudoers — Principe du moindre privilège

Le fichier /etc/sudoers définit précisément quels utilisateurs ou groupes peuvent exécuter quelles commandes avec des privilèges élevés. Il est édité avec visudo pour éviter les erreurs de syntaxe.

```
sudo visudo
# Donner tous les droits à un utilisateur jdupont ALL=(ALL:ALL) ALL
# Groupe sysadmin : tout sans mot de passe %sysadmin ALL=(ALL) NOPASSWD: ALL
# Groupe compta : uniquement useradd %comptabilite ALL=(root) /usr/sbin/useradd
# Développeurs : apt et systemctl seulement %developpeurs ALL=(root)
/usr/bin/apt, /bin/systemctl
```

1.1.5 Permissions fichiers — chmod, chown, umask

Permission	Valeur	Fichier	Répertoire
r (read)	4	Lire le contenu	Lister les fichiers (ls)
w (write)	2	Modifier	Créer / supprimer

Permission	Valeur	Fichier	Répertoire
x (execute)	1	Exécuter	Traverser (cd)

```
chmod 750 /var/confidentiel # rwxr-x--- (proprio=rwx, groupe=rx, autres=rien)
chown root:rh /var/confidentiel # Propriétaire=root, groupe=rh
umask 027 # Nouveaux fichiers = 640 par défaut
```

1.1.6 PAM — Pluggable Authentication Modules

PAM est le système d'authentification modulaire de Linux. Il permet de définir des politiques complexes : complexité des mots de passe, tentatives maximales, délais de connexion. Les fichiers de configuration se trouvent dans /etc/pam.d/.

```
sudo apt install libpam-pwquality
# Dans /etc/pam.d/common-password : password requisite pam_pwquality.so retry=3
minlen=12 dcredit=-1 ucredit=-1 ocredit=-1
```

- **minlen=12** : minimum 12 caractères
- **dcredit=-1** : au moins 1 chiffre
- **ucredit=-1** : au moins 1 majuscule
- **ocredit=-1** : au moins 1 caractère spécial

1.1.7 PAM + OpenLDAP — Gestion centralisée en entreprise

En environnement d'entreprise, PAM seul ne suffit pas pour gérer des centaines d'utilisateurs. La combinaison PAM + OpenLDAP permet une gestion centralisée et unifiée des identités sur tous les serveurs du réseau.

OpenLDAP est un annuaire réseau (protocole LDAP) qui centralise tous les comptes utilisateurs. PAM est configuré pour s'authentifier auprès de cet annuaire au lieu des fichiers /etc/passwd et /etc/shadow locaux.

- **Avantage 1** : Un seul compte par utilisateur pour tous les serveurs de l'entreprise
- **Avantage 2** : Politique de mot de passe appliquée centralement (expiration, complexité, historique)
- **Avantage 3** : Révocation immédiate d'un accès sur toute l'infrastructure en un seul point
- **Avantage 4** : Intégration avec Active Directory (Microsoft) via le protocole LDAP

```
# Installation OpenLDAP + module PAM LDAP sudo apt install slapd ldap-utils libpam-
ldap libnss-ldap -y
# Configurer PAM pour utiliser LDAP # /etc/pam.d/common-auth : auth sufficient
pam_ldap.so auth required pam_unix.so nullok_secure try_first_pass
```

Note : La mise en place complète de PAM+OpenLDAP est un projet à part entière. Cette combinaison est la base des systèmes d'authentification SSO (Single Sign-On) utilisés dans les grandes entreprises.

1.1.8 Script Bash — Expiration automatique des mots de passe (30 jours)

Ce script automatise la politique d'expiration pour tous les utilisateurs actifs. Il est planifié via cron pour s'exécuter le 1er de chaque mois.

```
#!/bin/bash # Script : expire_passwords.sh EXPIRE_DAYS=30 WARN_DAYS=7 while IFS=:
read -r username _ uid _; do if [ "$uid" -ge 1000 ] && [ "$username" !=
"nobody" ]; then sudo chage -M $EXPIRE_DAYS -W $WARN_DAYS "$username" echo
"[OK] $username : expiration $EXPIRE_DAYS jours" fi done < /etc/passwd
# Automatisation via cron (1er de chaque mois à 2h) sudo crontab -e # Ajouter : 0 2
1 * * /usr/local/bin/expire_passwords.sh >> /var/log/pwd_policy.log 2>&1
```

1.1.9 Pare-feu UFW — Gestion des ports

UFW (Uncomplicated Firewall) contrôle les connexions réseau entrantes et sortantes. Il est essentiel pour réduire la surface d'attaque du système.

```
sudo ufw enable sudo ufw default deny incoming sudo ufw default allow outgoing
sudo ufw allow from 192.168.2.0/24 to any port 22 # SSH réseau local uniquement
sudo ufw allow 80/tcp # HTTP sudo ufw allow 443/tcp # HTTPS sudo ufw deny
23/tcp # Bloquer Telnet sudo ufw deny 3389/tcp # Bloquer RDP sudo ufw limit
ssh # Protection brute-force
```

Port	Service	Recommandation sécurité
22	SSH	Restreindre aux IP de confiance + ufw limit
80	HTTP	Autoriser si serveur web, forcer redirect HTTPS
443	HTTPS	Autoriser si serveur web sécurisé
23	Telnet	BLOQUER — protocole non chiffré obsolète
3389	RDP	BLOQUER ou restreindre strictement
3306	MySQL	Bloquer en externe, localhost uniquement
2049	NFS	Bloquer en externe, restreindre par IP

1.2 — Checklist Prevent & Repair : Outils d'Audit Système

Note : Les outils suivants (Lynis, rkhunter, auditd) sont présentés ici et feront l'objet de tests approfondis par les autres membres du groupe. Chaque outil constitue un domaine d'exploration individuel.

1.2.1 Mises à jour automatiques — unattended-upgrades

Les mises à jour de sécurité sont la première ligne de défense. unattended-upgrades automatise leur application sans intervention manuelle.

```
sudo apt install unattended-upgrades sudo dpkg-reconfigure --priority=low
unattended-upgrades sudo unattended-upgrades --dry-run --debug # Tester sans
installer
```

1.2.2 Lynis — Audit complet et score de durcissement

Lynis est un outil d'audit open source qui analyse le système et produit un score de durcissement (Hardening Index) avec des recommandations classées par priorité. Il vérifie la configuration SSH, les droits fichiers, la politique de mots de passe, les services actifs, etc.

```
sudo apt install lynis sudo lynis audit system # Résultats : /var/log/lynis.log
et /var/log/lynis-report.dat
```

Score Lynis : Un indice de durcissement > 80/100 est considéré comme une bonne posture de sécurité en production. Ce test sera réalisé et documenté par un membre du groupe.

1.2.3 Détection de rootkits — rkhunter & chkrootkit

Les rootkits se dissimulent dans le système en modifiant le noyau ou les commandes système. Ces outils les détectent en comparant les comportements attendus aux observations réelles.

```
sudo apt install rkhunter chkrootkit sudo rkhunter --update # Mise à jour
des signatures sudo rkhunter --check # Analyse complète sudo chkrootkit
# Vérification rapide
```

1.2.4 Journalisation — auditd

auditd enregistre les événements système critiques : accès aux fichiers sensibles, changements de privilèges, connexions, commandes exécutées. Indispensable pour la traçabilité en entreprise.

```
sudo apt install auditd sudo systemctl enable --now auditd sudo auditctl -w
/etc/sudoers -p wa -k sudoers_changes sudo ausearch -k sudoers_changes #
Consulter les alertes
```

1.3 — Outils de Scan de Vulnérabilités

1.3.1 Nmap — Scan réseau et découverte de ports

Nmap (Network Mapper) est l'outil de référence pour la découverte réseau et l'audit de sécurité. Il identifie les hôtes actifs, les ports ouverts, les services en cours d'exécution et leurs versions.

```
sudo apt install nmap nmap --version # Vérifier
l'installation nmap -sn 192.168.2.0/24 # Découverte des hôtes nmap -A
-sV -O 192.168.2.100 # Scan complet + OS nmap --script vuln 192.168.2.100
# Vulnérabilités NSE nmap -A --script vuln 192.168.2.100 -oN scan.txt #
Sauvegarder
```

1.3.2 OpenVAS / Greenbone — Scan approfondi de vulnérabilités

OpenVAS (Open Vulnerability Assessment System), maintenu par Greenbone Networks, est l'équivalent open source de Rapid7 InsightVM. Il effectue des scans de vulnérabilités complets basés sur une base de données de CVE mise à jour régulièrement.

Contrairement à Nmap qui scanne en quelques minutes, OpenVAS effectue une analyse en profondeur qui peut durer plusieurs heures. Il explore chaque service détecté, teste des milliers de vecteurs d'attaque connus et produit un rapport CVE détaillé avec scores CVSS.

```
sudo apt install openvas sudo gvm-setup # Configuration initiale
(télécharge ~5000 plugins NASL + bases NVD) sudo gvm-start # Démarrer les
services sudo gvm-check-setup # Vérifier l'installation # Interface web :
https://127.0.0.1:9392
```

1.3.3 Nikto — Scan de vulnérabilités Web

Nikto teste les serveurs web contre plus de 6 700 fichiers/CGIs dangereux, vérifie les versions obsolètes et les problèmes de configuration HTTP.

```
sudo apt install nikto nikto -h http://192.168.2.100 # Scan basique nikto -
h http://192.168.2.100 -p 80,8080 -o rapport.html -Format html
```

GRANDE PARTIE 2 : TESTS & ANALYSES PRATIQUES

Cette partie présente les manipulations pratiques effectuées sur la machine Ubuntu 22.04 (paulo — 192.168.2.100). Elle répond aux trois questions du TD avec des résultats réels obtenus lors des tests.

Q1 — Configuration des Privilèges d'Accès

Environnement de test — Structure entreprise simulée

Mise en place d'une structure utilisateur simulant trois départements avec des niveaux d'accès différents, conformément au principe du moindre privilège.

```
# Création des groupes par département sudo groupadd sysadmin sudo groupadd
developpeurs sudo groupadd comptabilite
# Création des utilisateurs par département sudo useradd -m -s /bin/bash -G
developpeurs alice sudo useradd -m -s /bin/bash -G comptabilite bob sudo useradd -m
-s /bin/bash -G sysadmin charlie sudo passwd alice && sudo passwd bob && sudo
passwd charlie
```

Configuration de sudo par groupe

```
sudo visudo # Règles à ajouter : %sysadmin ALL=(ALL) NOPASSWD: ALL #
Admins : accès complet %developpeurs ALL=(root) /usr/bin/apt, /bin/systemctl # Dev
: apt + systemctl # comptabilite : aucun droit sudo (accès standard)
```

Répertoires partagés avec permissions adaptées

```
sudo mkdir -p /data/developpeurs /data/comptabilite sudo chown root:developpeurs
/data/developpeurs && sudo chmod 770 /data/developpeurs sudo chown
root:comptabilite /data/comptabilite && sudo chmod 750 /data/comptabilite ls -
la /data/
```

Application de la politique de mots de passe

```
sudo apt install libpam-pwquality -y # /etc/pam.d/common-password : # password
requisite pam_pwquality.so retry=3 minlen=12 dcredit=-1 ucredit=-1 # Expiration 30
jours pour tous les comptes sudo chage -M 30 -W 7 alice sudo chage -M 30 -W 7 bob
sudo chage -l alice # Vérifier
```

Configuration du pare-feu

```
sudo ufw enable sudo ufw default deny incoming sudo ufw default allow outgoing sudo
ufw allow from 192.168.2.0/24 to any port 22 sudo ufw deny 23/tcp && sudo ufw deny
3389/tcp sudo ufw status verbose
```

Résultat : alice (développeurs) peut utiliser apt/systemctl avec sudo mais rien d'autre. bob (comptabilité) n'a aucun accès sudo. charlie (sysadmin) a tous les droits. Le pare-feu bloque Telnet et RDP.

Extension possible : En environnement d'entreprise réel, cette structure serait couplée à OpenLDAP pour centraliser les comptes sur tous les serveurs du réseau, avec PAM configuré pour s'authentifier auprès de l'annuaire LDAP. Cela permet une gestion unifiée des identités et une révocation immédiate des accès sur toute l'infrastructure.

Q2 — Scan Réseau avec Nmap — Résultats Réels

Contexte du test

Machine testée : paulo (192.168.2.100) — Ubuntu 22.04 LTS

Outil : Nmap 7.80 — exécuté le 18 avril 2026

Scan 1 — Découverte des hôtes actifs

```
sudo nmap -sn 192.168.2.0/24
```

Résultat obtenu :

```
Nmap scan report for _gateway (192.168.2.1) Host is up (0.0013s latency). MAC: 74:24:9F:DE:F6:F4 Nmap scan report for paulo (192.168.2.100) Host is up. Nmap done: 256 IP addresses (2 hosts up) scanned in 2.21 seconds
```

Analyse : Seulement 2 hôtes actifs sur 256 adresses possibles. Réseau local peu exposé. La passerelle (routeur) 192.168.2.1 et la machine cible paulo sont les seuls équipements détectés.

Scan 2 — Ports, services et versions (résultats réels)

```
sudo nmap -sV 192.168.2.100 -oN scan_nmap_complet.txt
```

Port	État	Service / Version	Risque	Observation
22/tcp	open	OpenSSH 8.9p1 Ubuntu 3ubuntu0.14	Moyen	Version récente, OK
80/tcp	open	nginx 1.18.0 (Ubuntu)	Moyen	Serveur web principal
111/tcp	open	rpcbind 2-4 (RPC #100000)	Élevé	Inutile si NFS non requis
1935/tcp	open	rtmp? (MMPB TV — MediaSoup)	Moyen	Application de streaming
2049/tcp	open	nfs_acl 3 (RPC #100227)	Élevé	Partage NFS actif
3000/tcp	open	ssl/http — Node.js Express	Moyen	App MMPB TV (HTTPS)
5000/tcp	open	Werkzeug/3.1.3 Python/3.10.12	Moyen	App Flask Football PBM
5002/tcp	open	Werkzeug/3.1.5 Python/3.10.12	Moyen	Mini App Flask (test)
8080/tcp	open	Apache httpd 2.4.52 (Ubuntu)	Critique	CVE + phpMyAdmin exposé
9001/tcp	open	HTTP 403 Forbidden	Élevé	Service non identifié

Scan 3 — Vulnérabilités détectées (scripts NSE)

```
sudo nmap --script vuln 192.168.2.100
```

Vulnérabilité confirmée : CVE-2011-3192 — Apache ByteRange DoS

VULNERABLE — Apache byterange filter DoS (CVE-2011-3192) sur le port 8080. Le serveur Apache 2.4.52 est vulnérable à une attaque par déni de service lorsque de nombreuses plages d'octets (byte ranges) se chevauchent sont demandées simultanément. BID:49303 | Disclosure: 2011-08-19

Autres observations du scan NSE :

- **phpMyAdmin détecté** : /phpmyadmin/ accessible sur le port 8080 — interface d'administration de base de données exposée sur le réseau
- **broadcast-avahi-dos** : hôte 224.0.0.251 découvert mais non vulnérable (CVE-2011-1002)
- **Absence de vulnérabilités XSS/CSRF** : aucune faille XSS DOM/stored ni CSRF détectée sur les services HTTP
- **Applications personnelles exposées** : 3 apps en mode développement Werkzeug (ports 5000, 5002) — risqué en production

Actions correctives recommandées

```
# 1. Corriger la vulnérabilité Apache CVE-2011-3192 sudo apt upgrade apache2 -y
# 2. Bloquer phpMyAdmin en externe sudo ufw deny 8080/tcp
# 3. Restreindre NFS sudo ufw deny 2049/tcp && sudo ufw deny 111/tcp cat /etc/exports # Vérifier les exports NFS
# 4. Passer les apps Flask en production (remplacer Werkzeug) sudo apt install gunicorn -y gunicorn -w 4 app:app --bind 0.0.0.0:5000
# 5. Appliquer toutes les mises à jour sudo apt update && sudo apt upgrade -y
```

Q3 — Scan Approfondi des Vulnérabilités avec OpenVAS / GVM

Présentation et justification

OpenVAS (Open Vulnerability Assessment System), distribué sous le nom GVM (Greenbone Vulnerability Management), est l'outil sélectionné pour le scan approfondi de vulnérabilités. Il constitue l'alternative open source recommandée à Rapid7 InsightVM sur Ubuntu 22.04.

Contrairement à Nmap qui identifie ports et services en quelques minutes, OpenVAS effectue une analyse en profondeur de chaque service détecté en testant des milliers de vecteurs d'attaque connus issus de la base NVD. La durée d'un scan complet dépasse souvent une heure et peut atteindre plusieurs heures.

Choix d'OpenVAS vs Rapid7 : Rapid7 InsightVM est un outil propriétaire et payant. OpenVAS/GVM offre des capacités comparables gratuitement avec une base CVE mise à jour par Greenbone Networks. C'est l'outil de référence en environnement académique et en PME.

Etape 1 — Installation

```
sudo apt install openvas -y sudo gvm-check-setup # Vérifier l'état avant setup
```

Etape 2 — Problème rencontré : erreur PostgreSQL

Lors de l'exécution de gvm-setup, une erreur d'authentification PostgreSQL a bloqué l'initialisation :

```
(gvmdb): sql_open: fe_sendauth: no password supplied FATAL: password authentication failed for user " gvm"
```

Diagnostic : le fichier pg_hba.conf utilisait md5 pour les connexions locales, incompatible avec GVM qui se connecte via socket Unix sans mot de passe.

Etape 3 — Résolution : correction de pg_hba.conf

```
# Fichier : /etc/postgresql/14/main/pg_hba.conf # Ligne modifiée : # local all
all md5 → local all all trust sudo sed -i 's/local all
all md5/local all all
trust/' /etc/postgresql/14/main/pg_hba.conf sudo systemctl restart postgresql
```

Explication : La méthode 'trust' permet les connexions locales sans mot de passe via socket Unix. Elle est sécurisée en local car seuls les processus du même système peuvent accéder au socket PostgreSQL.

Etape 4 — Succes de gvm-setup

```
sudo gvm-setup  [>] Starting PostgreSQL service          OK [>] Migrating
database              OK [*] User created with password 'd5329419-6976-
4129-bf1f-797885cf4da8' [>] Updating GVM feeds (NVT, SCAP, CERT)      OK [+] GVM
feeds updated
```

Parametre	Valeur
URL interface web	https://127.0.0.1:9392
Login	admin
Mot de passe genere	d5329419-6976-4129-bf1f-797885cf4da8
Version GVM	GVM-21.4.3
Plugins NASL	~5 679 fichiers de detection de vulnerabilites
Bases NVD	nvdCVE-2.0-2002.xml a nvdCVE-2.0-2025.xml

Etape 5 — Demarrage et scan (a realiser)

```
sudo gvm-start # Interface web : https://127.0.0.1:9392
```

- **Connexion** : https://127.0.0.1:9392 avec login admin
- **Cible** : Configuration > Targets > New Target > Host : 192.168.2.100
- **Tache** : Scans > Tasks > New Task > profil 'Full and Fast'
- **Lancement** : Start — duree estimee : 1 a 3 heures pour 10 services
- **Resultats** : Scans > Reports — classes par severite CVSS

Grille de severite CVSS

Severite	Score CVSS	Exemples	Action requise
Critical	9.0 - 10.0	RCE, exploit public	Corriger immediatement (< 24h)
High	7.0 - 8.9	Privilege escalation	Corriger sous 48h
Medium	4.0 - 6.9	Config faible	Corriger sous 7 jours
Low	0.1 - 3.9	Info exposure	Planifier une correction

Statut : GVM installe et configure avec succes. Le scan complet de 192.168.2.100 sera lance et ses resultats CVE documentes dans la suite des travaux. Sur la base des resultats Nmap, OpenVAS devrait confirmer CVE-2011-3192 (Apache 8080), les risques NFS/rpcbind (ports 111/2049), phpMyAdmin expose, et les apps Flask Werkzeug en mode developpement.

CONCLUSION

Ce rapport a présenté une approche complète de la sécurité système sous Ubuntu 22.04, organisée autour de deux axes complémentaires.

La première partie a établi les fondations théoriques et conceptuelles : gestion des comptes utilisateurs et des groupes, application du principe de moindre privilège via sudo et /etc/sudoers, contrôle des permissions sur les fichiers, politiques d'authentification avancées via PAM (et son extension possible avec OpenLDAP pour les environnements d'entreprise), automatisation par scripts Bash, et protection réseau via UFW.

La seconde partie a mis en pratique ces concepts à travers des analyses concrètes sur la machine paulo (192.168.2.100). Le scan Nmap a révélé 10 services actifs dont une vulnérabilité critique confirmée (CVE-2011-3192 sur Apache 2.4.52), une interface phpMyAdmin exposée sur le réseau, des partages NFS ouverts, et trois applications personnelles tournant en mode développement Werkzeug. OpenVAS, dont l'installation et la configuration ont été documentées, permettra dans la suite des travaux un scan en profondeur avec analyse CVE complète.

Répartition des travaux du groupe : Chaque outil présenté constitue un domaine d'exploration individuel. Les tests Lynis, rkhunter, auditd et le scan OpenVAS complet feront l'objet de rapports complémentaires par les autres membres du groupe Hosts and Systems.

Objectif	Outil principal	Statut
Gestion utilisateurs & groupes	useradd, groupadd	Testé et documenté
Politique mots de passe	PAM + script Bash	Documenté (config + automatisation)
Gestion centralisée (entreprise)	PAM + OpenLDAP	Présenté — implémentation future
Contrôle pare-feu & ports	UFW	Testé et documenté
Audit système (checklist)	Lynis, rkhunter, auditd	Présenté — tests par autres membres
Scan réseau (hôtes & services)	Nmap 7.80	Testé — résultats réels obtenus
Vulnérabilités CVE confirmées	Nmap --script vuln	CVE-2011-3192 confirmé
Scan approfondi CVE	OpenVAS / Greenbone	Installation documentée — scan en cours